

VEDI Newsletter of December 15, 2023

[doc. web n. 9960948]

Provision of November 16, 2023

Register of Provisions

n. 527 of November 16, 2023

THE GUARANTOR FOR THE PROTECTION OF PERSONAL DATA

IN THE meeting today, attended by
Prof. Pasquale Stazione, President, Prof.
Ginevra Cerrina Feroni, Vice President, Dr.
Agostino Ghiglia and Attorney Guido Scorza, members, and
Dr. Claudio Filippi, Deputy Secretary General;

HAVING REGARD to Regulation (EU) 2016/679 of the European Parliament
and of the Council, of April 27, 2016, concerning
the protection of natural persons with regard to
the processing of personal data, as well as the free
movement of such data and repealing Directive
95/46/EC, "General Data Protection Regulation" (hereinafter "Regulation");

HAVING REGARD to Legislative Decree No. 196 of June 30, 2003, containing
"Code regarding the protection of personal data,
containing provisions for the adaptation
of the national legal system to Regulation (EU)
2016/679 of the European Parliament and of the Council, of
April 27, 2016, concerning the protection of
natural persons with regard to the processing of personal data,
as well as the free movement of such data and repealing
Directive 95/46/EC" (hereinafter "Code");

HAVING REGARD to Legislative Decree No. 101 of August 10, 2018, containing
"Provisions for the adaptation of national legislation
to the provisions of Regulation (EU)
2016/679 of the European Parliament and of the Council, of
April 27, 2016, concerning the protection of
natural persons with regard to the processing of personal data,
as well as the free movement of such data and repealing
Directive 95/46/EC";

HAVING REGARD to Regulation No. 1/2019 concerning the
internal procedures of external relevance,
aimed at carrying out the tasks and
exercising the powers assigned to the Guarantor for the
protection of personal data, approved by
resolution No. 98 of April 4, 2019, published in
G.U. No. 106 of May 8, 2019 and on www.gpdp.it, doc. web
n. 9107633 (hereinafter "Guarantor Regulation No.
1/2019");

HAVING REGARD to the documentation on file;

HAVING REGARD to the observations made by the Secretary
General pursuant to Article 15 of the Guarantor Regulation
No. 1/2000 on the organization and
functioning of the office of the Guarantor for the
protection of personal data, doc. web n. 1098801;

Reporter Prof. Pasquale Stazione;

PREMISED

1. The request and the investigative activity

With a note dated XX, Ms. XX submitted a complaint regarding the communication to third parties and the dissemination on the web (see URL: XX) of her personal data, as well as information related to health and investigations into crimes concerning her son XX, who passed away in XX.

In particular, some psychiatric evaluation reports conducted by Dr. XX were visible, as documentation part of the "Non-disseminable clinical material transmitted to participants in the XX under the obligation of professional secrecy." This document contained numerous pieces of information about XX (in one section the surname is clearly visible) related to biography, medical history, medications taken, crimes for which he was under investigation, as well as information about his mother (the complainant in the present proceeding). This documentation also contains information regarding another subject, referred to as "XX," whose psychiatric evaluation report was published.

What the complainant stated was verified by the Department, as part of a preliminary check carried out and documented in the records.

Following the request for information from the Office to Dr. XX, author of the aforementioned report (note dated XX, prot. n. XX), he provided feedback, stating that:

- "the document from which the complaint submitted by Ms. XX originates is part of the educational material prepared by the undersigned for the training event organized by CLUSTER S.r.l. (an organization for professional conferences in the medical-scientific field) titled XX, held in XX from June 21 to 23, XX, and aimed at Graduates in Medicine and Surgery, Specialists or Residents in Psychiatry";
- "as per established practice in training courses for Doctors, on this occasion, the presentation of some 'Clinical Cases' was planned, useful for commenting on and integrating the theoretical Reports given by the various Speakers";
- "my activity (...) involved the presentation of clinical cases through the commentary on Evaluations and Consultations, in which I personally participated in the course of my profession as a Technical Consultant for the Prosecutor and the Juvenile Court of XX, and the sharing of (...) summary educational material of the presented cases, on which the following wording was expressly

indicated: ‘Non-disseminable clinical material transmitted to participants in the XX under the obligation of professional secrecy’;

- “therefore, it was material shared solely for educational purposes with the participants in the course, who were also subject to the obligation of professional secrecy (from doctor to doctor), the dissemination of which was expressly prohibited”;

- “the undersigned believes he has correctly relied on the obligation of professional secrecy incumbent on the recipients of the educational material in question, affixing on it the wording “mentioned above”;

- “I am learning, however, only today, (...) that the document in question has been improperly published” and “thus made available on the internet. While strongly reiterating that I am completely unrelated to this behavior (...), I affirm that I can in no way be attributed any responsibility either for the publication of the educational material – to which, in any case, I did not give any consent – nor for the possibility of it being found and ‘downloaded’ by individuals other than the participants in the ECM course to which this material was exclusively directed.”

Also in light of the statements made by the doctor, with note dated XX, prot. n. XX, the Company Cluster s.r.l. (hereinafter “the Company”), which organized the training event XX, was asked to provide, pursuant to Article 157 of the Code, certain elements of information useful for the evaluation of the case. In a note dated March 1, the Company responded to the aforementioned request for information from the Authority, stating, among other things, that:

- “Cluster, unfortunately, learned only upon reviewing this request for clarifications that, even following the successful outcome of the initiatives promoted by Dr. XX, content and data treated during the realization of the event XX continued to be accessible on the web (through a link attributable to the same) which it believed it had handled with the appropriate precautions and in a manner absolutely compatible with the type of data”;

- “In short, Cluster was completely unaware that there was ongoing (...) online dissemination of personal data processed in the context of XX and promptly took steps to remove from its management system the content accessible through the link (...) ensuring that this initiative could have excluded any possible further dissemination”;

- “By virtue of the assignments undertaken in the context of the event, Dr. XX therefore transmitted in digital format to Cluster the psychiatric reports he prepared at the conclusion of assignments he carried out as a CTU of the Court of XX, expressly requesting Cluster that this educational material be graphically formatted and made available to the participants at the end of the event so that they could consult it and gain greater awareness of the content addressed”;

- “Cluster then uploaded the documentation received onto its management system (CMS – Congress Management System ...) in adherence to the request received, limiting the dissemination of the educational material to the only medical doctors already enrolled in the course (i.e., to individuals bound by the duty of confidentiality and professional secrecy)”;

- “The documentation in question was formed and in any case prepared by Dr. XX (...) in execution of the assignments attributed to him by the Court of XX, and Cluster merely received this documentation for the purpose of organizing the event. It is worth noting here that these reports, like all educational material typically addressed during medical-scientific events, ‘belong’ to the subject who drafts and prepares them, and the related work of ingenuity is protected by Article 1 of Law No. 633/1941 (...);

- “This means that, applying the aforementioned regulations to the relationship between the Teacher and the Provider, the latter is prohibited from making any modifications to the work of ingenuity made available by the teacher, as well as from using the teacher's educational material without prior authorization. The only margin of maneuver (if it can be defined as such) allowed to the Provider concerns modifications that are, so to speak, ‘aesthetic’, related to editing or formatting, essentially aimed at facilitating the consultation of the educational material during the event”;

- “Any violations of the provisions in force regarding the processing of personal data contained in the text of the document may be attributed to Cluster only to the extent of improper control activity regarding the documentation”;
- “However, this does not imply that Cluster should not have paid greater attention in verifying that Dr. XX had the accuracy to completely remove the patient’s personal details, rendering the data effectively anonymous in compliance with the provisions regarding the processing of special data. Cluster can only reiterate its regret in this regard”;
- “In this case, the web module for the event XX was activated, and through the website www.clustersrl.it, the 26 registrations of the participants were collected. The day before the start of the course, as always, the possibility of registration for new participants was disabled, and the course was hidden on www.clustersrl.it. In theory, therefore, the URL in question should no longer have been accessible. As mentioned, at the end of the course, Prof. XX and Dr. XX asked us to make the educational material presented available to the 26 participants involved. It is plausible that, in order to facilitate its dissemination among these 26 individuals, this material was uploaded as an attachment on the web module of the event and that this URL (no longer otherwise accessible) was sent via email to the 26 interested parties to allow them to download the PDF containing the reports prepared by Dr. XX”;
- “It seems possible to exclude without fear of contradiction that the communication to third parties of the data and their online dissemination could be due to a malfunction of the management system itself or to conduct that was preordained or simply negligent on the part of Cluster”;
- “The fact (learned from the invitation to respond) that the URL generated by Cluster's CMS was made accessible on the web, therefore certainly results from unlawful conduct carried out by individuals who, improperly and without any authorization from Cluster (nor as learned from Dr. XX, the holder of the intellectual work), have taken possession of data and content not belonging to them, making it lawful to disclose them”;
- “the online dissemination, or rather the uploading to the CMS management system, likely occurred starting from the end date of the event”;
- “the technical and organizational measures usually adopted by Cluster, as described in the preceding paragraphs, are deemed adequate to ensure the correct processing of personal data collected by the Company, which operated under the belief of limiting the circulation of data to what was strictly necessary to execute the event exclusively aimed at subjects required to comply with the duty of confidentiality and professional secrecy.”

2. Assessments of the Department on the processing carried out and notification of the violation referred to in Article 166, paragraph 5 of the Code

In relation to the described facts, the Office, with a note dated XX (prot. no. XX), notified the Company, pursuant to Article 166, paragraph 5, of the Code, of the initiation of proceedings for the adoption of measures referred to in Article 58, paragraph 2, of the Regulation, inviting it to submit written defenses or documents to the Authority or to request to be heard by the Authority (Article 166, paragraphs 6 and 7, of the Code; as well as Article 18, paragraph 1, of Law No. 689 of 24/11/1981).

In particular, the Office, in the aforementioned act, deemed that the Company had carried out processing of personal data, concerning health and judicial matters, in violation of the basic principles of processing referred to in Articles 5, 6, 9, 10, and, allowing access, without the overcoming of any computer authentication procedure, to the aforementioned web address, of the obligations regarding security referred to in Article 32 of the Regulation, as well as Articles 2-septies and 2-octies of the Code.

With a note dated XX, Cluster, recalling what was already highlighted in the note dated XX, submitted its defensive memoranda, in which it particularly emphasized that:

- “the factual circumstances presented in note XX converge with the statements made by Dr. XX during the investigation regarding the substantial course of the historically occurred facts. The respective narratives indeed confirm that the educational material used during XX was prepared and formed by Dr. XX on the occasion of professional assignments conferred by the Court of XX, as it also appears confirmed that the same Dr. XX, the sole holder of the copyright on the educational material,

transmitted the documentation to Cluster so that it could be made available to the participants”;

- “no negligent behavior can therefore be attributed to Cluster (as a mere recipient of such educational material) regarding the processing and initial collection of health and judicial data used by Dr. XX for the drafting of psychiatric assessments. It is similarly believed that it can be agreed that it was precisely Dr. XX who was the only subject required both to collect the appropriate consent from the interested parties for the data to be transmitted to third parties (including Cluster itself) and to do what was necessary to anonymize the personal data contained in his report. It should be noted that Cluster has never had direct relationships with the patients mentioned in the medical reports concerning us”;

- “upon receiving the educational material, Cluster, at the request of Dr. XX, uploaded the educational material onto the company management system (CMS) without the designated person exercising due attention and care regarding the content of the received documentation and omitting, in particular, to verify that said material was compliant with the principles established by the Code regarding data protection”;

- “the uploading of the material onto the management system is, however, an act that generated a mere service URL for internal use, which by itself is inadequate to cause the dissemination of data (of any kind) on the web. The dissemination of the data in question on the web does not therefore result from the uploading of the data onto the internal management system but depended exclusively on further conduct carried out by one (or more) of the 26 doctors who, having received the URL in question via email, disseminated the data acting in violation of the professional secrecy to which they are bound by virtue of their qualification”;

- “the preceding narrative thus highlights that the dissemination on the web of personal data belonging to special categories was made possible only as a result of a series of concurrent unlawful acts starting from the transmission of the non-anonymized educational material by Dr. XX to Cluster itself, concluding with the material acts attributable to one or more students who published the URL in question”;

- “it does not therefore seem incorrect to assert that the only potential negligent behavior attributable to Cluster in this context could only be the sending via email of the URL to the 26 participants, a conduct that, even from a causal perspective, could not have caused the dissemination of the URL on the web”;

- “Cluster cannot therefore be charged or sanctioned for any violation related to the (failure to) collect consent for the processing of the patient’s data (which is an obligation that Dr. XX was required to fulfill, who was also required to anonymize the data before proceeding with the transmission to Cluster itself); similarly, Cluster cannot be charged and consequently sanctioned for the dissemination on the web of the material in question which is, the relevant regulations;

- “the conduct attributable to Cluster, even from a causal perspective, regarding the alleged violation can be considered limited or otherwise marginal. On the other hand, the actions taken by Dr. XX and the participants had a decisive causal impact on the occurrence of the alleged violations”;

- “among the types of data routinely processed by Cluster, neither health data attributable to a specific individual nor judicial data are included. The circumstance subject to this proceeding is therefore entirely exceptional, anomalous, and completely irregular compared to the ordinary and habitual business activity of Cluster and occurred due to the choice of the Scientific Managers to use, as teaching material, concrete clinical cases that they had come to know through their freelance professional activity. The processing of particular categories of data is not part of the ordinary business activity of Cluster; the number of individuals involved in the violation: the reconstruction of the facts, carried out following the investigation promoted by the Illustrious Guarantor (as confirmed both by Dr. XX’s account and that of Cluster) leads to the conclusion that the alleged violation should be considered limited to the data of the mentioned individual”;

- “in the absence of elements that allow for the establishment of the dies a quem of the alleged violation, it must therefore be considered that its duration is confined between the day on which the Illustrious Guarantor received the complaint that led to this proceeding and the day on which the contents were actually removed from the web”;

- “the violation has a ‘non-intentional’ character according to the definition provided by the WP253 Guidelines, which attribute to the term ‘unintentional’ the absence of intention on the part of the data

controller to cause the violation (...); it must therefore be excluded that there exists any malicious or intentional characteristic on the part of Cluster, which has already expressed its sincere regret for the incident and can at most be considered guilty of having transmitted, out of excessive trust in the participants, the material to the attendees once the event was concluded”;

- “(...) Cluster was completely unaware that there was an ongoing (albeit in a very limited way) online dissemination of personal data processed within the context of XX and, after learning from the request for information received pursuant to Article 157 of the Code that even following the initiatives promoted by Dr. XX the dissemination of the data could not be considered contained, promptly took action to remove the contents accessible through the link mentioned in the introduction, ensuring that this initiative could have excluded any possible further dissemination”;

- “Cluster therefore believes that it has promptly adopted efficient and effective measures as quickly as possible in response to the emergence of the violation”;

- “following the alleged violation, Cluster has arranged for a re-examination of the types of data stored on its CMS and, following the review conducted, it can be excluded that the CMS contains data other than the common data collected in the context of the ordinary business activity carried out”;

- “also with regard to the data processed, the CMS complies with the technical-organizational requirements set forth by the GDPR. The CMS used by Cluster is structured to collect, by default setting, only the personal data strictly necessary for the completion of the registration of operators belonging to the medical scientific sector and, again by default setting, does not allow the disclosure of the collected data to parties other than Age.Na.S.”;

- “the data contained in the CMS can only be accessed by internal personnel with the appropriate authorizations for data processing in accordance with the relevant regulations;”

individual access credentials and no

data circulation to the outside is provided except

to the extent necessary for the provision of

educational credits to the learners”;

- “Cluster reiterates (...) that the dissemination of data to third parties brought to the attention of the Illustrious Guarantor did not occur as a result of a lack

or violation of access systems to its

business management system and that, similarly, the

alleged violation did not occur as a result of system errors,

unauthorized access, or the use of

insufficient security measures”;

- “Cluster believes that the removal from its

management system of the contents accessible

through the link mentioned in the preamble, along with

the verification carried out regarding the exclusion of further

possible forms of data circulation, serves to

exhaust the spectrum of possible activities to

remedy the alleged violation”;

- “Cluster has indeed acknowledged that:

- its negligent behavior should be contextualized and

considered within the framework of the

negligent conduct certainly exhibited by the

other parties involved in this proceeding

as well as the participants in the ECM course (who are

not parties to this proceeding) who have

actually disseminated the contents on the web;

- any negligent conduct attributable to

Cluster is in any case traceable to the mere sending of

a URL via email to 26 participants bound by

the duty of confidentiality and professional secrecy, and,

in any case, results from a single processing ("the same or linked processing operations") of data; the purpose underlying the processing of the data in question is to facilitate the dissemination ("dissemination") of the same among the participants in the ECM course;

- the data processing requested from Cluster is necessary in order to fulfill a function of

public interest that is indeed regulated by agreements of public relevance;

- the scope of data processing is limited, at most, to a national level;

- its behavior is not characterized by intent or malice;

- it promptly removed the link from its management system, thus adopting, as quickly as possible, the appropriate measures to remedy the violation";

- "with respect to the various thresholds indicated by Article 83 GDPR and the Guidelines 04/2022, Cluster acknowledges that the company's revenue achieved in the last 10 years of activity has always been below 2,000,000 euros and, also considering the size of the company, which currently has only 1 employee, believes that the requirements may exist to proceed with a reduction of 0.2% from the initial amount due to the low level of severity of the violation as resulting from the consideration of all the indicated elements";

- "if the Illustrious Guarantor (...) does not deem it necessary to conclude the initiated procedure with the archiving of the position, Cluster requests that the prescription of the contested administrative offense be declared, as the five-year term set by Article 28

paragraph 1 of Law 689/1981 has elapsed. In this regard, Cluster has specified that the only negligent conduct attributable to it consists of sending via email

the URL containing the educational material to the 26 learners who registered for XX and that the subsequent dissemination of said educational material on the web cannot in any way be attributed to Cluster";

- "it must therefore be considered that the conduct attributable to Cluster occurred at the time of sending the URL via email once the training event of June 21-23 XX was concluded, with the consequence that the five-year term, established under penalty of expiration by Article 28, paragraph 1 of Law 689/1981, for the

contest of any administrative offense must be considered expired on a date certainly prior to the initiation of the procedure and in any case prior to the completion of any act having an interruptive effect".

The Company has therefore requested to proceed with the archiving of the aforementioned procedure.

On XX, the hearing requested by the Company took place. In this circumstance, it was specified that:

- “the relationship between the company and the scientific responsables is not equal (...); this led the company to accept the request of the Doctor to communicate to the learners the URL from which it was possible to download the educational material in question”;
- “the simple uploading to the CMS system would not have produced any dissemination or propagation if the URL had not been sent via email and subsequently shared by one or more of the 26 recipients of the same”;
- “the company had a legitimate expectation of confidentiality towards the recipients of the email, considering that they were doctors subject to professional secrecy”;
- “from what happened, the company has not reported any type of advantage”;
- “the emotional tension of Ms. XX who decided to initiate this procedure is understood”.

3. Outcome of the investigative activity

Taking note of what was represented by the Company in the documentation on file, in the defense briefs and during the hearing, it is observed that:

1. personal data is understood to mean “any information concerning an identified or identifiable natural person (‘data subject’); an identifiable natural person is one who can be identified, directly or indirectly, with particular reference to an identifier such as a name, an identification number, data related to location, an online identifier, or one or more characteristic elements of their identity. physical, physiological, genetic, psychological, economic, cultural or social” (art. 4, par. 1, point n. 1 of the Regulation) and, by anonymous data, it is meant “(...) information that does not relate to an identified or identifiable natural person or to personal data rendered sufficiently anonymous to prevent or no longer allow the identification of the data subject” (cf. Recital n. 26 of the Regulation and WP29 Opinion 05/2014 on Anonymisation techniques, adopted on April 10, 2014);
2. anonymization cannot be considered achieved through the mere removal of the identifying details of the data subject or their replacement with a pseudonymous code. Anonymized data is such only if it does not allow, in any way, the direct or indirect identification of a person, taking into account all means (economic, information, technological resources, skills, time) available to those (data controller or other subject) attempting to use such tools to identify a data subject. The risk of re-identification of the data subject must be carefully assessed considering “all means, [...], which the data controller or a third party can reasonably use to identify that natural person directly or indirectly. To ascertain the reasonable likelihood of using the means to identify the natural person, the set of objective factors should be taken into account, including the costs and time required for identification, considering both the technologies available at the time of processing and technological developments” (cf. again Recital n. 26 of the Regulation and WP29 Opinion 05/2014 on Anonymisation techniques, adopted on April 10, 2014);
3. personal data concerning deceased persons continue to be subject to the protections provided by the regulations on personal data protection (as highlighted by the Authority in decisions of January 10, 2019, n. 2, web doc n. 9084520 and April 29, 2021, n. 173, web doc n. 9672313);
4. personal data must be “processed in a manner that ensures adequate security (...) including

protection, through appropriate technical and organizational measures, against unauthorized or unlawful processing and against accidental loss, destruction or damage ("integrity and confidentiality") (art. 5, par. 1, lett. f) of the Regulation);

5. regarding the security of processing, art. 32 of the Regulation establishes that "taking into account the state of the art and the costs of implementation, as well as the nature, scope, context and purposes of the processing, and the risk of varying likelihood and severity for the rights and freedoms of natural persons, the data controller and the processor shall implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk, which include, among others, where appropriate: the pseudonymization and encryption of personal data [...]" (par. 1) and that "in assessing the appropriate level of security, particular consideration shall be given to the risks presented by the processing which arise particularly from the destruction, loss, alteration, unauthorized disclosure or access, in a manner that is accidental or unlawful, to personal data transmitted, stored or otherwise processed" (par. 2);

6. the Authority, in approving the Code of Conduct of the Veneto Region for the use of health data for educational and scientific publication purposes (web doc n. 9535402, <https://www.gpdp.it/web/guest/home/docweb/-/docweb-display/docweb/9535402>), which identifies specific guarantees and measures to protect patients, stated that: "the use of personal data for educational and scientific publication purposes by healthcare professionals operating within the organizational structure of the data controller can only occur after the adoption of specific anonymization and pseudonymization measures" (...); "if it is not possible to proceed with the anonymization of the data, the data controller must obtain specific consent from the data subject, which, once collected, will still subject the data to pseudonymization (art. 5 of the Code)" (decision of January 14, 2021, n. 7, web doc n. 9535354).

4. Conclusions

In light of the evaluations set forth above, considering the statements made by the data controller during the investigation and noting that, unless the act constitutes a more serious offense, anyone who, in a proceeding before the Authority, falsely declares or certifies news or circumstances or produces false acts or documents is liable under art. 168 of the Code ("Falsehood in declarations to the Authority and interruption of the execution of the tasks or exercise of the powers of the Authority"), it is noted that the elements provided by the Company in the aforementioned defensive memoranda and during the hearing are not suitable to accept the request for dismissal, as they do not fully overcome the objections notified by the Office with the aforementioned initiation act of the proceeding. In particular, while maintaining the assessment regarding the failure to adopt specific anonymization measures for the data processed by the doctor who drafted the documentation and subsequently used it for educational purposes, it is noted that, if the conduct related to sending the URL via email to the doctors participating in the course concluded at the time of the training event of June 21-23, XX, with the consequent start of the five-year term established by art. 28, paragraph 1, law n. 689/1981, according to which "the right to collect the sums due for the violations indicated from this law it is prescribed within the term of five years from the day on which the violation was committed", the conduct concerning the obligations regarding the security of processing cannot be considered concluded, persisting until the moment the violation became apparent. As mentioned above, the obligation on the data controller to implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk, which includes the ability to ensure on a permanent basis the confidentiality, integrity, availability, and resilience of systems as well as a procedure to regularly test, verify, and evaluate the effectiveness of the technical and organizational measures in order to ensure the security of processing (art. 32, par. 1, lett. b) and d) of the Regulation) was in place until the moment the violation was ascertained, lasting until the initiation of the investigation by the Authority. For these reasons, the illegality of the processing of personal data carried out by the Company is noted, in the terms stated in the reasoning, for having failed to provide adequate measures to ensure on a permanent basis confidentiality and to regularly verify and evaluate the effectiveness of the technical and organizational measures, for example, by adopting a computer

authentication procedure to access the described documentation containing personal data, for which no assessment had been made regarding the adequacy of the adopted anonymization measures. In this context, considering that the Company has removed the link from its management system, the conditions for the adoption of the corrective measures referred to in art. 58, par. 2, of the Regulation do not currently exist.

5. Adoption of the injunction order for the application of the administrative pecuniary sanction and accessory sanctions (arts. 58, par. 2, lett. i) and 83 of the Regulation; art. 166, comma 7, of the Code). The violation of arts. 5 and 32 of the Regulation is subject to the application of the administrative pecuniary sanction pursuant to art. 83, par. 4 and 5, of the Regulation. Considering that the violation of arts. 5 and 32 occurred as a result of a single conduct, art. 83, par. 3, of the Regulation applies, according to which the total amount of the administrative pecuniary sanction does not exceed the amount specified for the most serious violation. Given that, in this case, the most serious violation concerns art. 5, par. 1, lett. f), of the Regulation, subject to the administrative sanction provided for by art. 83, par. 5, of the Regulation, the total amount of the sanction is to be quantified up to €20,000,000 or, for companies, up to 4% of the total annual worldwide turnover of the previous financial year, if higher. It should be noted that the Guarantor, pursuant to arts. 58, par. 2, lett. i) and 83 of the Regulation, as well as art. 166 of the Code, has the power to “impose an administrative pecuniary sanction pursuant to article 83, in addition to [other] [corrective] measures referred to in this paragraph, or in lieu of such measures, depending on the circumstances of each individual case” and, in this context, “the Board [of the Guarantor] adopts the injunction order, which also provides for the application of the accessory administrative sanction of its publication, in whole or in part, on the Guarantor's website pursuant to article 166, comma 7, of the Code” (art. 16, comma 1, of the Guarantor Regulation no. 1/2019). The aforementioned administrative pecuniary sanction imposed, depending on the circumstances of each individual case, must be determined in amount taking into account the principles of effectiveness, proportionality, and deterrence, indicated in art. 83, par. 1, of the Regulation, in light of the elements provided for in art. 83, par. 2, of the Regulation. In light of the above and, in particular, the duration of the violation as well as the categories of personal data involved (personal data, health data, and judicial data), it is believed that the level of severity of the violation committed by the Company is high (cf. European Data Protection Board, “Guidelines 04/2022 on the calculation of administrative fines under the GDPR” of May 23, 2023, point 60). Considering the Company's turnover and evaluating a series of elements as a whole, including that the Authority became aware of the event following a complaint from the interested party regarding the processing of personal data concerning them and their child (art. 83, par. 2, lett. h) of the Regulation) and the Company has removed the link from its management system (art. 83, par. 2, lett. c) of the Regulation), it is deemed appropriate to determine the amount of the pecuniary sanction provided for by art. 83, par. 5, lett. a) of the Regulation, in the amount of €18,000.00 (eighteen thousand) for the violation of arts. 5 and 32, as an administrative pecuniary sanction deemed, pursuant to art. 83, par. 1, of the Regulation, effective, proportionate, and deterrent. It is also considered that the accessory sanction of publication on the Guarantor's website of this provision, provided for by art. 166, comma 7 of the Code and art. 16 of the Guarantor Regulation no. 1/2019, should apply, also considering the type of personal data subject to unlawful processing. Finally, it is noted that the conditions referred to in art. 17 of Regulation no. 1/2019 concerning internal procedures with external relevance, aimed at carrying out the tasks and exercising the powers entrusted to the Guarantor, are met.

ALL OF THE ABOVE PREMISED, THE GUARANTOR declares the illegality of the processing of personal data carried out by Cluster s.r.l., for the violation of Articles 5 and 32 of the Regulation.

ORDERS

pursuant to Articles 58, par. 2, lett. i) and 83 of the Regulation, as well as Article 166 of the Code, to Cluster s.r.l., with registered office in XX (10123), Via Carlo Alberto n. 32, C.F./VAT number

07530720015, to pay the sum of euro 18,000.00 (eighteen thousand) as an administrative pecuniary sanction for the violation indicated in this provision; it is noted that the offender, pursuant to Article 166, paragraph 8, of the Code, has the option to settle the dispute by payment, within 30 days, of an amount equal to half of the imposed sanction.

ORDERS

the aforementioned Company, in case of failure to settle the dispute pursuant to Article 166, paragraph 8, of the Code, to pay the sum of euro 18,000.00 (eighteen thousand) according to the methods indicated in the attachment, within 30 days from the notification of this provision, under penalty of the adoption of subsequent enforcement actions in accordance with Article 27 of Law No. 689/1981.

DISPOSES

pursuant to Article 166, paragraph 7, of the Code, the full publication of this provision on the Guarantor's website and considers that the conditions referred to in Article 17 of Regulation No. 1/2019 concerning internal procedures with external relevance, aimed at carrying out the tasks and exercising the powers entrusted to the Guarantor, are met.

Pursuant to Article 78 of the Regulation, Articles 152 of the Code, and Article 10 of Legislative Decree No. 150/2011, against this provision it is possible to appeal before the ordinary judicial authority, under penalty of inadmissibility, within thirty days from the date of communication of the provision itself or within sixty days if the appellant resides abroad.

Rome, November 16, 2023

THE PRESIDENT

Stanzione

THE REPORTER

Stanzione

THE DEPUTY SECRETARY GENERAL

Filippi